

GOVERNANCE, RISK & COMPLIANCE (GRC) REPORT

NVIDIA Regional R&D and Production Hub Network

Project ID: NVIDIA-REG-RD-2026-1106

Document Classification: Confidential

Prepared For: NVIDIA Regional R&D and Production Hub

Primary Technical Scope: Network Infrastructure, Cybersecurity, Governance, Risk and Compliance

1. Executive Summary

This Governance, Risk and Compliance (GRC) report evaluates the proposed network infrastructure for the NVIDIA Regional R&D and Production Hub against the requirements defined in the Request for Quote (RFQ).

The proposed environment is designed to support high-performance research, software development, multimedia production, AI creation and LLM-related workloads. The architecture incorporates network segmentation, a collapsed-core multilayer switching design, dedicated infrastructure services, centralized AAA/RADIUS authentication, Access Control Lists (ACLs), Layer 2 port security, switch hardening, an edge firewall, VPN functionality and a dedicated DMZ VLAN.

Netify Network Documentation : [BXL-Hamilton-2026-Netify-main](#)

2. Audit Objectives

The objectives of the audit are to:

- Assess the delivered design against NVIDIA's requirements.
- Identify compliance and control gaps.
- Compare documented configurations with the Packet Tracer implementation.
- Establish whether security controls are present where documented.
- Provide clear and actionable recommendations before go-live.

3. Audit Scope

The audit covers the documented network architecture, physical and logical assets, VLANs, IP addressing, servers, switches, firewall, network services, security controls, access controls, configurations, and relevant procurement and budget information.

The GRC assessment focuses on three primary areas:

Governance: Establishing accountability, security ownership, administrative controls and documented operational processes.

Risk: Identifying threats, vulnerabilities, configuration weaknesses and architectural risks that could affect confidentiality, integrity and availability.

Compliance: Assessing whether the proposed architecture and controls satisfy the stated RFQ requirements and support recognized cybersecurity control principles.

4. Audit Evidence

The assessment is based on:

1. [NVIDIA RFQ](#) – client requirements.
2. [Network Design Document](#) – architecture, configurations, security controls, access matrix, procurement and budget.
3. [Cisco Packet Tracer File](#) – submitted network implementation.

5. Asset Inventory

Asset ID	Asset / Service	Asset Category	Qty	VLAN / Zone	Services / Function	Access / Security Controls	Data Held / Referenced
AST-001	Dell Precision High-End AI Tower	Physical Asset – AI Workstation	10	VLAN 30	AI workstation	VLAN segmentation, Access port mode, VLAN 1 shutdown	Departmental documents
AST-002	Dell OptiPlex Staff Workstation	Physical Asset – Staff Workstation	38	VLAN 10,20,40,50,60	Staff workstation	VLAN 1 shutdown	Departmental documents
AST-003	HP Enterprise LaserJet MFP Printer	Physical Asset – Printer	4	VLAN 10,20,40,60	Network printing	Static IP; departmental access; VLAN segmentation, switchport mode access	Departmental documents
AST-004	Structured Cable & Assembly	Physical Asset – Network Infrastructure	1	All VLAN/Zones	Network connectivity	Not specified	Not specified
AST-005	Dell PowerEdge Infrastructure Rack Server	Server	3	VLAN 99	Infrastructure server	Not specified	Not specified
AST-006	Application Server	Server	1	VLAN 200	HTTP, HTTPS, TFTP, Syslog, NTP, Email, FTP	ACL permits HTTP, HTTPS and FTP	Company web application; files stored on FTP server
AST-007	DHCP - DNS Server	Server / Network Service	1	VLAN 100	DHCP, DNS / name resolution	DNS access permitted by ACL	DNS static resource records
AST-008	AAA Server	Server / Security Service	1	VLAN 100	AAA / RADIUS	Authentication, authorization and accounting	Authentication and accounting information
AST-009	Cisco Catalyst 3650 Multilayer Switch	Switch – Core	1	VLAN 10, 20, 30, 40, 50, 60, 100, 200	VLAN segmentation, inter-VLAN routing	SVI ACL, AAA/RADIUS, trunking	Network configuration
AST-010	Cisco Catalyst 2960 Access Switches	Switch – Access	6	VLAN 10,20,30,40,50,60	Access switching / VLAN connectivity	Port Security, sticky MAC, maximum 1 MAC, violation shutdown	Switch configuration / MAC addresses
AST-011	Cisco ASA 5506-X Edge Firewall	Firewall	1	Outside / Inside	Firewall, WebVPN / SSL VPN	Stateful firewall, ACL, WebVPN	Firewall and VPN configuration
AST-012	Cisco ISR 4331 Edge/ISP Services Router	Router	1	WAN / ISP	Edge / ISP routing	Edge routing	Routing configuration
AST-013	Cisco Cable Modem	Modem	1	WAN / ISP	Edge / ISP routing	Provides Internet	Not specified
AST-014	Support Sector A	Logical Network / Sector	1	VLAN 10	DHCP, DNS, HTTP, HTTPS, FTP	ACL-SUPPORT1	Not specified
AST-015	Support Sector B	Logical Network / Sector	1	VLAN 20	DHCP, DNS, HTTP, HTTPS, FTP	VLAN segmentation	Not specified
AST-016	Production Sector	Logical Network / Sector	1	VLAN 30	DHCP, DNS, HTTP, HTTPS, FTP	VLAN segmentation	Not specified
AST-017	Management / Secretariat	Logical Network / Sector	1	VLAN 40	DHCP, DNS, HTTP, HTTPS, FTP	VLAN segmentation	Not specified
AST-018	IT Department	Logical Network / Sector	1	VLAN 50	DHCP, DNS, HTTP, HTTPS, FTP	DNS to 192.168.100.3; HTTP to 192.168.200.2; internal 192.168.0.0/16 denied	Not specified
AST-019	Study Sector	Logical Network / Sector	1	VLAN 60	DHCP, DNS, HTTP, HTTPS, FTP	VLAN segmentation	Not specified
AST-020	Server DMZ Infrastructure	Logical Network	1	VLAN 100	DNS, DHCP, HTTP, HTTPS, AAA, RADIUS, FTP	VLAN/SVI configuration	Not specified
AST-021	Application Hub Platform / DMZ	Logical Network	1	VLAN 200	Application platform	ACL permits HTTP, HTTPS and FTP	Application data; FTP files
AST-022	FTP Service	Network Service	1	VLAN 200 / DMZ	File transfer	TCP 21 / TCP 20 permitted by ACL	Files stored on FTP server
AST-023	HTTP Service	Network Service	1	VLAN 200 / DMZ	Company web application	TCP 80 permitted by ACL	Company web application
AST-024	HTTPS Service	Network Service	1	VLAN 200 / DMZ	Secure web access	TCP 443 permitted by ACL	Not specified
AST-025	DHCP Service	Network Service	1	VLANs 10–60	Automatic IP address assignment	DHCP pools; ip helper-address 192.168.100.3	IP/network configuration parameters
AST-026	DNS Service	Network Service	1	VLANs 10–60	Translates hostnames to IP addresses	Not specified	DNS resource records
AST-027	RADIUS Server / AAA Service	Security Service	1	VLAN 100	Centralized AAA	UDP port 1645; RADIUS	Authentication and accounting information
AST-028	VPN / WebVPN	Security Service	1	ASA Outside	Clientless SSL VPN / remote access	VPN_POLICY; SSL clientless; RemoteAccess tunnel group	VPN authentication credentials
AST-029	VLAN 99 – Server Room	Logical Network	1	VLAN 99	Server room segmentation	VLAN separation	Not specified
AST-029	5-Year Premium Support & Maintenance SLA	Service / Contract	1	All VLAN/Zones	24/7/4h support and maintenance	Vendor support contract	Not specified

Report : [Asset Inventory](#)

The asset inventory identifies the documented assets within the scope of the audit and provides a reference point for subsequent compliance and risk assessments.

It includes:

- Physical infrastructure and endpoint assets
- Servers and application infrastructure
- Switches, firewall and routing infrastructure
- Network and security services
- VLANs and logical network segments
- Services and the data or information identified as being associated with them

6. Applicability Note

The applicability assessment is based on the purpose and activities of the NVIDIA Regional R&D and Production Hub, rather than solely on the technology deployed at the site. The assessment follows the decision flow in 02_Regulations.md §2.5 and the information provided in the NVIDIA RFQ and project documentation.

Regulation / Standard	Applies	Reasoning
GDPR	Applies	The organisation has 48 employees and processes personal data in an EU Member State.
NIS2 / Belgian NIS2 Act	Applies— Important Entity	NVIDIA designs and manufactures computer hardware and conducts R&D activities; manufacturing and research organisations are sectors covered by NIS2, placing the organisation within the relevant important entity scope.
ISO/IEC 27001:2022 / ISO/IEC 27005	Applies — Voluntary	ISO/IEC 27001 certification is not compulsory based on the information provided, but it provides a recognised information-security management framework; ISO/IEC 27005 supports the associated information-security risk-management approach.

CyFun (CCB)	Applies	CyFun is the Belgian cybersecurity framework identified as a control source in the project brief and provides a recognised route for demonstrating alignment with the Belgian NIS2 requirements.
Cyber Resilience Act (CRA)	Does not apply	The Cisco network devices identified in the dossier may fall within CRA product categories, but the relevant CRA obligations apply to the manufacturers of those products rather than NVIDIA as the buyer/deployer of the equipment.
AI Act	Uncertain	The dossier indicates that Production-sector workstations are used for internal LLM training and R&D, but it does not establish NVIDIA's role as provider or deployer or the applicable AI-system risk category; these facts are required to determine applicability.
DORA	Does not apply	The Regional Hub is not identified as a financial-sector entity or as providing the type of financial-sector services covered by DORA.
SOC 2	Does not apply	The dossier does not identify a US client-facing service or service-organisation activity that would establish SOC 2 applicability.

The regulations and frameworks considered applicable to this audit are therefore GDPR, NIS2/Belgian NIS2 Act, and CyFun, with ISO/IEC 27001/27005 treated as voluntary recognised standards. The AI Act remains uncertain and should not be used as a compliance finding until NVIDIA's role and the relevant AI-system risk classification are established.

7. Audit Checklist

Audit Checklist							
ID	Area	Requirement	Control (Framework + Clause)	Check question	Evidence source	Pass condition	Result
AC-01	Access Control	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.5; CyFun PR.AA-01; CIS Controls 5.2	Are administrative passwords and RADIUS shared secrets unique, sufficiently strong, and not reused or based on default credentials?	Network_Analysis.pdf – AAA/RADIUS configuration; key Cisco123; local user admin / Cisco123	All administrative credentials and shared secrets are unique, non-default, strong, and appropriately protected.	Fail
AC-02	Access Control	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.5; CyFun PR.AA-03; CIS Controls 6.4	Does remote VPN access require MFA or another appropriately strong multi-factor authentication mechanism?	Network_Analysis.pdf – VPN configuration shows username vpnuser password ... encrypted; no second factor configured	Remote VPN access requires MFA or an equivalent approved strong authentication mechanism.	Fail
AC-03	Access Control	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.5; CyFun PR.AA-01	Are access-layer switch ports restricted to authorized devices using port security?	Network_Analysis.pdf – maximum 1, mac-address sticky, violation shutdown; verification commands documented	All applicable endpoint ports enforce one authorized MAC address, sticky learning, and an appropriate violation response, with verification evidence.	Partially Pass
NS-01	Network Segmentation	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.22; CyFun PR.AC-5 / PR.JR-01	Does the firewall restrict traffic originating from the internal server network to only required destinations and services?	Network_Analysis.pdf – ASA ALLOW, ALL ACL permits 192.168.100.0/24 to any	The firewall follows least privilege and explicitly permits only documented business-required destinations and services.	Fail
NS-02	Network Segmentation	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.22; CyFun PR.AC-5	Do departmental ACLs consistently prevent unnecessary inter-VLAN communication while allowing required business services?	Proposal §4 – IT/VLAN 50 ACL example; VLAN and ACL configuration documentation	Each departmental ACL documents required destinations/services and denies unauthorized internal lateral movement.	Partially Pass
NS-03	Network Segmentation	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.22; CyFun PR.AC-5	Is the DMZ logically isolated from internal departmental networks through dedicated VLAN and access-control rules?	Network_Analysis.pdf – VLAN 200, 192.168.200.0/24, Application Server 192.168.200.2, ACL documentation	DMZ assets reside in a dedicated segment and traffic between DMZ, internal networks, and external networks is explicitly controlled.	Partially Pass
LM-01	Logging & Monitoring	NIS2 Art. 21(2)(a)	ISO/IEC 27001:2022 A.8.15; CyFun DE.CM-03	Is administrative access centrally logged through AAA/RADIUS, including sufficient information for accountability?	Network_Analysis.pdf – aaa accounting exec default start-stop group radius	Administrative sessions are centrally logged and the logging configuration captures the level of activity required by the security policy.	Partially Pass
DP-01	Data Protection	NIS2 Art. 21(2)(h)	ISO/IEC 27001:2022 A.8.24; CyFun PR.DS-02	Are sensitive file transfers protected using an encrypted protocol such as SFTP or FTPS?	Network_Analysis.pdf – FTP test uses ftp 192.168.200.2 with cisco/cisco credentials	File transfers and authentication data are encrypted in transit using an approved secure protocol.	Fail
DP-02	Data Protection	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.24; CyFun PR.AA-01	Are production passwords, VPN credentials, and shared secrets excluded from general project documentation?	Asset_Inventory.xlsx – cleartext Cisco123, cisco/cisco, and VPN credentials	No live credentials or security secrets appear in documents intended for broad project circulation.	Fail
SC-01	Supply Chain	NIS2 Art. 21(2)(d)	ISO/IEC 27001:2022 A.5.19 / A.5.20; CyFun GV.SC-05	Do supplier and maintenance agreements contain explicit cybersecurity obligations?	Proposal §5 and maintenance/SLA documentation	Supplier contracts define applicable security requirements such as vulnerability handling, incident notification, confidentiality, and cooperation obligations.	Fail
GV-01	Governance	NIS2 Art. 20	ISO/IEC 27001:2022 A.5.2; CyFun GV.RR-02	Is a client-side owner responsible for the site's cybersecurity posture after project handover?	Proposal §1 and maintenance documentation – Netlity project roles are listed, but no NVIDIA security owner is identified	A named NVIDIA role/person owns security governance, risk acceptance, monitoring, and post-handover security maintenance.	Fail
GV-02	Governance & Documentation	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.9; CyFun PR.PS-01	Are network configurations, device models, interfaces, VLANs, and addressing consistent across the project documentation?	Network_Analysis.pdf, Proposal, Asset_Inventory.xlsx	All authoritative documents contain consistent device models, interfaces, VLANs, IP addressing, and security-zone definitions.	Fail
GV-03	Governance & Documentation	RFQ §3 Deliverables	ISO/IEC 27001:2022 A.5.15; CyFun GV.OG-03	Does the project dossier contain the required Access Control Matrix defining inter-department permissions?	RFQ §3 and Proposal §3 – addressing/VLAN table present, but no explicit permissions matrix	A documented matrix identifies permitted and denied communication between departments, servers, DMZ resources, and external networks.	Fail
GV-04	Governance & Configuration	NIS2 Art. 21(2)(i)	ISO/IEC 27001:2022 A.8.9; CyFun PR.PS-01	Are unused interfaces disabled and are privileged credentials protected from cleartext exposure in device configurations?	Network_Analysis.pdf – unused ports set to shutdown; service password-encryption; enable secret	Unused interfaces are disabled and privileged credentials are not stored in cleartext within device configurations.	Fail

Report : [Audit Checklist](#)

The audit assessed 14 controls across access control, network segmentation, logging and monitoring, data protection, supply chain, governance, documentation, and configuration management.

Overall Result:

<i>Failed</i>	10 controls
<i>Partially Pass / Partial</i>	5 controls
<i>Fully Passed</i>	0 controls

Overall conclusion: *Unsatisfactory / High remediation priority*

The assessment identifies material weaknesses in both the technical security baseline and the supporting governance and documentation. No control could be confirmed as fully compliant based on the evidence reviewed.

8. Audit Findings

F-01 — Weak and reused administrative credentials

 Critical

Related check: AC-01

Observation

The AAA/RADIUS shared key and local administrator password both use Cisco123.

Evidence

Network_Analysis.pdf – AAA/RADIUS configuration.

Reference

ISO/IEC 27001:2022 A.8.5; CyFun PR.AA-01; CIS 5.2. NIS2 Art. 21(2)(i).

Risk

Compromise of these credentials could provide unauthorized administrative access to network devices and security configurations.

Recommendation

The network/security owner should immediately replace and rotate all exposed credentials and shared secrets with unique strong values. Use approved secrets management where available.

Rating: Likelihood 3 × Impact 3 = **9**

F-02 — VPN access without MFA High

Related check: AC-02

Observation

VPN access uses username/password authentication and no second factor is configured.

Evidence

Network_Analysis.pdf – VPN configuration.

Reference

ISO/IEC 27001:2022 A.8.5; CyFun PR.AA-03; CIS 6.4. NIS2 Art. 21(2)(j).

Risk

A compromised VPN password could provide unauthorized remote access to the internal network.

Recommendation

The network/security owner should implement MFA or an approved equivalent strong multi-factor authentication mechanism for all remote VPN access and verify its effectiveness before go-live.

Rating: Likelihood 2 × Impact 3 = 6

F-03 — Inconsistent verification of access-layer port security Medium

Related check: AC-03

Observation

Port-security configuration is documented, including maximum MAC address, sticky learning and violation shutdown. However, evidence does not demonstrate that these controls are consistently applied and verified across all applicable endpoint ports.

Risk

Inconsistent port-security enforcement could allow unauthorized devices to connect to network access ports.

Recommendation

Verify port-security configuration across all applicable access-layer ports and retain configuration and verification evidence.

Rating Likelihood 2 × Impact 2 = 4

F-04 — Server network permits unrestricted traffic Critical

Related check: NS-01

Observation

The ASA ALLOW_ALL ACL permits 192.168.100.0/24 to communicate with any destination.

Evidence

Network_Analysis.pdf – ASA ALLOW_ALL ACL.

Reference

ISO/IEC 27001:2022 A.8.22; CyFun PR.AC-5 / PR.IR-01. NIS2 Art. 21(2)(i).

Risk

A compromised server could communicate with unnecessary internal or external destinations, increasing opportunities for lateral movement or data transfer.

Recommendation

The network/security owner should identify required flows and replace ALLOW_ALL with explicit destination/service rules and default deny.

Rating: Likelihood 3 × Impact 3 = **9**

F-05 — Incomplete departmental ACL restrictions

 Medium

Related check: NS-02

Observation

An IT/VLAN 50 ACL example is documented, but complete required destinations and services are not defined for all departmental ACLs. Evidence: Proposal §4 – IT/VLAN 50 ACL example.

Reference

ISO/IEC 27001:2022 A.8.22; CyFun PR.AC-5. NIS2 Art. 21(2)(i).

Risk

Unnecessary inter-VLAN communication could allow a compromised endpoint to access other departmental systems.

Recommendation

The network/security owner should document required inter-VLAN flows and implement corresponding allow/deny rules.

Rating: Likelihood 2 × Impact 2 = **4**

F-06 — DMZ traffic controls not fully evidenced

 High

Related check: NS-03

Observation

The DMZ uses VLAN 200 (192.168.200.0/24) and contains application server 192.168.200.2, but complete traffic restrictions are not demonstrated. Evidence: Network_Analysis.pdf – VLAN 200 and ACL documentation.

Reference

ISO/IEC 27001:2022 A.8.22; CyFun PR.AC-5. NIS2 Art. 21(2)(i).

Risk

An exposed DMZ system could have unnecessary connectivity to internal resources if traffic is not sufficiently restricted.

Recommendation

The network/security owner should document permitted DMZ flows and enforce explicit ACL rules between DMZ, internal, and external networks.

Rating: Likelihood 2 × Impact 3 = 6

F-07 — Administrative logging coverage not fully demonstrated

● Medium

Related check: LM-01

Observation

AAA accounting is configured with start-stop RADIUS accounting, but complete activity logging and retention are not demonstrated. Evidence: Network_Analysis.pdf – aaa accounting exec default start-stop group radius.

Reference

ISO/IEC 27001:2022 A.8.15; CyFun DE.CM-03. NIS2 Art. 21(2)(a).

Risk

Incomplete administrative logs could limit attribution and investigation of unauthorized configuration changes.

Recommendation

The security/logging owner should verify required logging, central collection, retention, and administrator traceability across relevant devices.

Rating: Likelihood 2 × Impact 2 = 4

F-08 — Unencrypted FTP used for file transfer

● High

Related check: DP-01

Observation

The application server 192.168.200.2 is accessed using FTP with cisco/cisco credentials. Evidence: Network_Analysis.pdf – FTP test.

Reference

ISO/IEC 27001:2022 A.8.24; CyFun PR.DS-02. NIS2 Art. 21(2)(h).

Risk

FTP can expose authentication credentials and transfer data to network observers.

Recommendation

The application/server owner should replace FTP with SFTP, FTPS, or another approved encrypted protocol and rotate the exposed credentials.

Rating: Likelihood 2 × Impact 3 = 6

F-09 — Credentials exposed in project documentation

 High

Related check: DP-02

Observation

The asset inventory contains cleartext Cisco123, cisco/cisco, and VPN credentials. Evidence: Asset_Inventory.xlsx.

Reference

ISO/IEC 27001:2022 A.8.24; CyFun PR.AA-01. NIS2 Art. 21(2)(i).

Risk

Anyone accessing the project documentation could obtain credentials for network, VPN, or application services.

Recommendation

The project/security owner should remove exposed credentials, rotate them immediately, and store operational secrets in an approved secrets-management system. Any tooling cost should remain within the EUR 300,000 ceiling.

Rating: Likelihood 2 × Impact 3 = 6

F-09 — Supplier cybersecurity obligations not defined

 Medium

Related check: SC-01

Observation

Supplier and maintenance documentation does not explicitly define vulnerability handling, incident notification, confidentiality, and security cooperation requirements.

Evidence

Proposal §5 and maintenance/SLA documentation.

Reference

ISO/IEC 27001:2022 A.5.19 / A.5.20; CyFun GV.SC-05. NIS2 Art. 21(2)(d).

Risk

Supplier-related security incidents or vulnerabilities may lack clearly defined notification and response responsibilities.

Recommendation

The procurement/contract owner should update applicable agreements with explicit cybersecurity requirements and responsibilities.

Rating: Likelihood 2 × Impact 2 = **4**

F-11 — No identified client-side cybersecurity owner

 Medium

Related check: GV-01

Observation

Project roles are documented, but no NVIDIA security owner is identified for the site's cybersecurity posture after handover. Evidence: Proposal §1 and maintenance documentation.

Reference

ISO/IEC 27001:2022 A.5.2; CyFun GV.RR-02. NIS2 Art. 20.

Risk

Security governance, risk acceptance, monitoring, and maintenance may lack clear accountability after handover.

Recommendation

The NVIDIA project/service owner should assign a named cybersecurity owner and document post-handover responsibilities.

Rating: Likelihood 2 × Impact 2 = **4**

F-12 — Inconsistent network documentation

 Medium

Related check: GV-02

Observation

Network device models, interfaces, VLANs, IP addressing and security-zone information are not fully consistent across the Network Analysis, Proposal and Asset Inventory documentation.

Risk

Inconsistent documentation can lead to configuration errors, ineffective security controls and difficulties during incident response or maintenance.

Recommendation:

Establish an authoritative network configuration baseline and reconcile all project documentation against it before handover.

Rating: Likelihood 2 × Impact 2 = 4

F-13 — Access Control Matrix not provided

 Medium

Related check: GV-03

Observation

The project dossier contains VLAN and addressing information but does not provide the required Access Control Matrix defining permitted and denied communication between departments, servers, DMZ resources and external networks.

Risk:

Without a documented communication matrix, firewall and ACL rules cannot be consistently validated against approved business requirements.

Recommendation:

Create and approve an Access Control Matrix covering permitted and denied communication, required services, source/destination zones and applicable security controls.

Rating: Likelihood 2 × Impact 2 = 4

F-14 — Privileged credential protection not adequately demonstrated

 High

Related check: GV-04

Observation:

Unused interfaces are correctly configured as shutdown; however, the evidence does not demonstrate adequate protection of privileged credentials in device configurations. The broader project evidence also contains exposed security secrets.

Risk:

Exposure or inadequate protection of privileged credentials could facilitate unauthorized administrative access to network devices.

Recommendation:

Verify that privileged credentials and secrets are protected using approved mechanisms and are not stored or documented in cleartext. Rotate any credentials that have already been exposed.

Rating: Likelihood 2 × Impact 3 = 6 — High

Audit Finding Summary : [Audit Findings based on Area](#)

9. Risk Register

Risk ID	Finding ID	Risk	Area	Control	L	I	Score	Rating	Owner	Priority
RR-01	F-01	Weak/reused administrative credentials	Access Control	ISO 27001 A.8.5	3	3	9	Critical	NVIDIA IT / Security	Immediate
RR-02	F-02	VPN remote access does not require MFA	Access Control	ISO 27001 A.8.5	2	3	6	High	NVIDIA IT / IAM	Before go-live
RR-03	F-03	Access-layer port security is not consistently evid	Access Control	ISO 27001 A.8.5	2	2	4	Medium	NVIDIA IT / Network Security	Before go-live
RR-04	F-04	Server network permits unrestricted destinations	Network Segmentation	ISO 27001 A.8.22	3	3	9	Critical	NVIDIA IT / Network Security	Immediate
RR-05	F-05	Departmental ACLs do not consistently enforce le	Network Segmentation	ISO 27001 A.8.22	2	2	4	Medium	NVIDIA IT / Netify	Before go-live
RR-06	F-06	DMZ traffic restrictions are not fully demonstrat	Network Segmentation	ISO 27001 A.8.22	2	3	6	High	NVIDIA IT / Netify	Before go-live
RR-07	F-07	Administrative logging and accountability are incc	Logging & Monitoring	ISO 27001 A.8.15	2	2	4	Medium	NVIDIA IT / SOC	Before go-live
RR-08	F-08	FTP exposes credentials and data	Data Protection	ISO 27001 A.8.24	2	3	6	High	NVIDIA IT / Network Security	Before go-live
RR-09	F-09	Live credentials and secrets are exposed in projec	Data Protection	ISO 27001 A.8.24	2	3	6	High	NVIDIA IT / Netify	Immediate
RR-10	F-10	Supplier cybersecurity obligations are insufficient	Supply Chain	ISO 27001 A.5.19/A.5.20	2	2	4	Medium	NVIDIA Procurement / IT	Before contract renewal / go-live
RR-11	F-11	No named client-side cybersecurity owner after h	Governance	ISO 27001 A.5.2	2	2	4	Medium	NVIDIA Senior Management	Before go-live
RR-12	F-12	Network/security documentation is inconsistent	Governance & Documentation	ISO 27001 A.8.9	2	2	4	Medium	Netify Architecture Group / NVIDIA IT	Before go-live
RR-13	F-13	Required Access Control Matrix is not defined	Governance & Documentation	ISO 27001 A.5.15	2	2	4	Medium	Netify Architecture Group	Before go-live
RR-14	F-14	Privileged credential protection is not adequately	Governance & Configuration	ISO 27001 A.8.9	2	3	6	High	NVIDIA IT / Netify	Before go-live

Report : [Risk Register](#)

The risk register consolidates the security risks identified during the assessment of the NVIDIA Regional R&D and Production Hub architecture. Risks were derived from failed and partially passed audit controls. Each risk has been assessed using the defined likelihood and impact criteria, with the resulting score determining the overall risk rating. The register is intended to support prioritisation, ownership and remediation tracking.

9.1 Risk Rating Methodology

Include the rating scale before the register:

Likelihood	Definition
3 – High	No effective control prevents exploitation; a common or well-known technique can be used.
2 – Medium	A partial control exists, or the attacker requires an initial foothold.
1 – Low	Several conditions must align, or insider access is generally required.

Impact	Definition
3 – High	Significant impact to sensitive data, multiple systems, or production continuity.
2 – Medium	Impact primarily limited to one service, sector, or security function.
1 – Low	Limited impact with straightforward recovery.

Risk Score = Likelihood × Impact

Score Rating

9	 Critical
6	 High
3-4	 Medium
1-2	 Low

9.2 Risk Register

For the main report, the risk register can be available: [Risk Register](#)

Risk distribution

 Critical: 2
 High: 5
 Medium: 7
 Low: 0

Total risks: 14

The distribution indicates that the highest-priority risks concern privileged access, unrestricted network connectivity, credential exposure, remote access authentication and protection of data transfers.

9.3 Management Priorities

Immediate priorities:

AC-01: Replace weak/default credentials and RADIUS secrets and rotate exposed credentials.

NS-01: Replace the ALLOW_ALL firewall rule with documented least-privilege rules.

DP-02: Remove credentials and secrets from project documentation and rotate exposed credentials.

AC-02 / DP-01: Implement VPN MFA and replace FTP with an encrypted transfer protocol.

GV-01: Appoint a named NVIDIA cybersecurity owner before handover.

Before production go-live

The remaining High and Medium risks should be remediated, or formally risk-accepted by the appropriate NVIDIA authority, before production deployment.

9.4 Top Three Priorities

Based on the risk register, the following three priorities should be addressed first because they have the highest risk scores (9 – Critical) and directly affect the confidentiality and security of the wider environment.

1. Remediate AC-01 — Administrative credentials

Replace the weak/reused Cisco123 administrative password and RADIUS shared secret, and rotate credentials exposed in project documentation. These credentials could provide privileged access to network infrastructure.

2. Remediate NS-01 — Restrict server network traffic

Replace the ALLOW_ALL firewall rule for 192.168.100.0/24 with documented least-privilege rules. This should be prioritised because unrestricted server connectivity could allow a compromised system to communicate with unnecessary internal or external destinations.

3. Remediate DP-02 — Remove exposed credentials

Remove live credentials and secrets from the project documentation and rotate any credentials that have already been exposed. This is prioritised because the documentation itself provides access information that could be used to compromise the environment.

These three should be addressed before lower-rated findings because they represent the highest-scoring risks and provide direct attack paths or access to the environment. MFA and encrypted file transfer should then follow as immediate/pre-production priorities.

9.5 Limitations

The assessment was based on the evidence provided in the project dossier, including the Network Design Document, Asset Inventory, Proposal documentation and Cisco Packet Tracer implementation.

The following could not be fully verified:

- Consistent enforcement of port-security settings across all applicable ports.
- Complete effectiveness of departmental and DMZ ACLs through live traffic testing.
- Full command-level administrative logging and retention.
- Whether additional credentials or secrets exist outside the reviewed documents.
- Whether supplier agreements outside the provided evidence contain additional cybersecurity requirements.
- The existence of any undocumented post-handover cybersecurity owner.
- Whether all documented configurations match the actual production environment.

The conclusions therefore reflect the evidence available for review and should not be interpreted as the result of a full penetration test, live configuration audit or operational effectiveness assessment.

9.6 . Summary

The assessment identified 14 security risks in the proposed NVIDIA Regional R&D and Production Hub environment.

- Two risks are rated Critical, five High, and seven Medium.

- The most urgent concern is the use of weak and reused administrative credentials, including credentials exposed in project documentation.
- The internal server network also has a firewall rule that allows communication to any destination rather than only required services.
- Remote VPN access does not currently use MFA, and FTP is used without encryption.
- Several security controls are present, but their consistent implementation could not be fully verified from the available evidence.
- NVIDIA should first secure administrative credentials, restrict server-network traffic, and remove and rotate exposed credentials.
- The remaining High and Medium risks should be remediated or formally risk-accepted before production go-live.